



Malware protection policy

This document is property of Data & More ApS and commercial in confidence. The document is intended to be read with the permission of Data & More ApS only. If you do not have explicit permit to read the document, stop reading the document and contact the document owner immediately.

David Junge

using Cyberday.ai

06.10.2026, 15:27

Version #6

Introduction

Malware protection policy describes the safeguards implemented to prevent malware from entering the organization's environment, to identify and report on malware or suspected malware attacks, and to define appropriate actions to eliminate and recover from malware related incidents.

There are many potential sources of malware, including malicious websites, social media, USB memory sticks or other removable media, emails and software or documents copied over the internet.

Malware infections can spread from an infected system and lead to the loss of data or access to IT systems, intensive and constly recovery work, severe disruption of business operations and to reputational damage or even fines. Malware is a constantly evolving threat and needs appropriate safeguards to be controlled.

Security tasks are tasks assigned to ISMS users on organization's information security management system.

Employee guidelines are general guidelines related to using company information in a secure way. Guidelines are assigned to all employees or selected units and their acceptance is monitored automatically through organization's ISMS.

Security tasks

Security tasks related to malware protection describe the core team's responsibilities in relation to e.g. maintaining an up-to-date malware protection software on all relevant devices, limiting riski user actions, gathering information about malware and

training personnel when relevant.

Malware protection

Automatic blocking and detecting of unauthorized hardware

Our organization has defined policies and measures to detect and prevent the usage of unauthorized hardware within the organization's network and infrastructure.

Description

D&M has defined policies and measures to detect and prevent the usage of unauthorized hardware within the organization's network and infrastructure.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

DORA RTS Risk management framework - Article 2: General elements of ICT security policies, procedures, protocols, and tools

Automatic blocking and detecting of unauthorized software

Our organization has defined policies in place to prevent or at least detect the use of unauthorized programs.

Description

Automatic deployment and updates

The Company infrastructure runs on a network of Ubuntu servers hosted in decentralized data centers. Employees use their laptops to access the infrastructure, but only DevOps has the rights to install software that is deployed via Ansible.

This gives a transparent and exact installation process for all production servers.

Real-time monitoring and detection: The organization has set up a continuous monitoring process that detects and alerts the IT team about the presence or use of unauthorized applications on the system

Use of Intrusion Detection Systems: The organization has installed intrusion detection systems (IDS) to scan the network traffic for any signs of unauthorized software.

Assurance:

 Medium

Priority:

Low 

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 8.7: Protection against malware...

+7 requirements

Automatic file scan by malware protection software

The anti-malware software used by the organisation must be configured to automatically scan files. The scan should be done when a file is downloaded, opened and when it is opened from network storage.

Description

Automatic file scan configuration: The organization has configured the anti-malware software to scan files automatically.

Implementation of the scanning process upon download: The organization has made sure that the anti-malware software is set to instantly start a scanning process when a file is being downloaded from the internet or transferred from an external storage device.

Implementation of the scanning process upon opening: The organization has implemented the measure where the anti-malware software would immediately initiate a scan when a file is opened. This reduces the risk of malware spread within the organization's systems.

Implementation of the scanning process for network storage access: The organization has instructed the anti-malware software to automatically scan any files which are accessed from network storage. This prevents the spread of malware from infected network directories.

Assurance:



Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber Essentials - MWP-02: Automatic file scan by anti-malware software...

+2 requirements

Automatic website scan by malware protection software

The malware protection software used by the organisation must be configured to automatically scan websites. The scan should be done when accessing a website.

Description

Automatic website scan configuration: The organization has configured the malware protection software to perform automatic scans whenever a website is accessed.

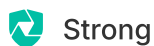
Immediate scan upon website access: The organization has implemented a measure where the malware protection software promptly initiates a scanning process every time a website is loaded on the organization's systems.

Integration with web browsers: The organization has seamlessly integrated the malware protection software with all active web browsers, ensuring every website accessed undergoes a comprehensive scan to identify potential security threats.

Real-time threat detection and blocking: The organization has equipped the malware protection software with real-time threat detection capabilities, enabling it to block access to harmful websites immediately, thus preventing the download of malicious content.

Automatic updates of threat database: The organization has instated an automatic update process for the malware protection software to keep its database of known threats current, improving the efficiency and efficacy of website scans.

Assurance:



Strong

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber Essentials - MWP-03: Automatic website scan by anti-malware software...

+2 requirements

Blacklisting

The malware protection software must block connections to malicious websites using deny listing for example. Not doing this is acceptable only if there is clear documented business need not to and the organisation fully understands and accepts the associated risks.

Description

Implementation of deny listing: The organization has implemented deny listing in the malware protection software, which prevents connections to listed malicious websites.

Updating of deny list: The organization has established a process that ensures the deny list is regularly updated, adding new malicious or untrusted websites as they are identified.

Blocked connections to malicious sites: The organization has configured the malware protection software to automatically block any attempted connections to denlisted websites.

Assessment of business needs: In cases where business needs may require access to websites on the deny list, the organization has put a thorough assessment process in place to evaluate the risk factors.

Risk acceptance and documentation: The organization has a system where, if after assessment, the access to a listed site is deemed necessary, the associated risks are fully understood, accepted, and documented.

Alternative safeguards: In the event access to a blocked site is granted due to business necessity, the organization has arranged for alternative security measures to mitigate the associated risks.

Periodic re-evaluation: The organization has implemented a periodic re-evaluation process to review the needs and risks associated with accessing the websites listed in deny list.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber Essentials - MWP-04: Blocking connections to malicious websites

Configuring automatic anti-malware scanning of removable media

The organization configures anti-malware software to automatically scans a data transferred via removable media. This involves setting up the software to perform automatic scans on files when they are downloaded, opened, or accessed from network storage, including removable media like USB drives and other external storage devices. Any files transferred via these media are promptly scanned for malware before they can be utilized.

Description

Anti-malware software is configured to automatically scan data transferred via removable media. This configuration ensures that files are scanned when downloaded, opened, or accessed from network storage, including USB drives and other external storage devices. Any files transferred via these media are promptly scanned for malware before they can be utilized. A formal security policy is in place, enforced through the anti-malware software's configuration, mandating the automatic scanning of all files accessed from removable storage. Additionally, the use of removable media connected to servers is not permitted within the organization.

Assurance:



Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

CIS 18 - 10.4: Configure Automatic Anti-Malware Scanning of Removable Media

Creating an allowlist for approved libraries

The organization implements an allowlist for approved libraries by requiring digital signatures from trusted certificate authorities for all libraries.

The organization uses application whitelisting to ensure only approved libraries load and configures security policies to block unapproved libraries.

Description

A comprehensive allowlist for approved libraries is maintained, ensuring that only trusted components are utilized within the organization's IT environment.

Digital signatures from recognized certificate authorities are required for all libraries before their inclusion on the allowlist.

Application whitelisting mechanisms are configured to permit the loading of only these approved libraries, thereby preventing unauthorized code execution.

Security policies are established and enforced to actively block any libraries not present on the allowlist, providing a robust defense against malicious or unapproved software.

The allowlist is regularly reviewed and updated to reflect changes in approved software and to incorporate new security requirements.

Assurance:

 Medium

Priority:

Normal

Status:

Mostly done

Owner:

DJ D. Junge

Linked requirements:

CIS 18 - 2.6: Allowlist Authorized Libraries...

+2 requirements

Defining requirements for malware protection

The organisation must determine what are the requirements for protection against malware. The following should be considered:

- Risk assessment

- Legal and regulatory requirements
- Business and operational needs
- Technology environment
- Budget and resources

The organisation must define and implement organisational measures for protection against malware based on the defined requirements.

Description

Requirement definition process: The organization has established a formal process to determine the requirements for malware protection. This process ensures all relevant factors are considered systematically.

Technical and resource planning: The organization has evaluated its current technology environment, budget, and available resources. This evaluation has informed the selection of feasible and effective malware protection solutions.

Alignment with business needs: The organization has analyzed its business and operational needs to ensure that the malware protection requirements support critical processes and protect essential assets without impeding operations.

Compliance and legal considerations: The organization has identified and incorporated all applicable legal, statutory, regulatory, and contractual requirements into its malware protection strategy to ensure full compliance.

Risk-based approach: The organization has conducted a comprehensive risk assessment to identify malware-related threats and vulnerabilities. The findings from this assessment have been used as a key input for defining malware protection requirements.

Implementation of protective measures: Based on the defined requirements, the organization has implemented a set of specific organizational and technical measures to provide robust protection against malware across the enterprise.

Assurance:

 Medium

Priority:

High ↑

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

DORA RTS Risk management framework - Article 11b: System security

Detecting and blocking access to dangerous websites

The organization must identify the types of websites that staff should and should not have access to.

The organization must consider blocking access to the following types of sites (either automatically or by other means):

- websites with a file upload function, unless this is permitted for a specific business need
- known or suspected malicious websites (e.g. distributing malware or containing phishing content)
- command and control servers
- websites distributing illegal content

Description

Website classification: The organization has identified different types of websites to establish which ones the staff should and should not have access to.

Blocked websites with a file upload function: The organization has decided to block access to websites with file upload functionalities, unless they are specifically required for business operations.

Blocked known or suspected malicious websites: The organization has blacklisted particular categories of known or suspected harmful websites. This includes websites distributing malware or containing phishing content.

Blocked command and control servers access: The organization has blocked access to command and control servers, which hackers typically use to maintain communication with compromised systems.

Blocked access to websites distributing illegal content: The organization has disallowed access to websites known to distribute illegal content as a measure to prevent potential legal and compliance issues.

System for regular website review: The organization has instated a system for the regular review of websites deemed safe for accessing to ensure they haven't become a source of threat or illegal content.

Safe browsing solutions: The organization has implemented solutions that filter internet content in real-time, blocking potentially harmful websites before they can be accessed.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 8.7: Protection against malware...
+4 requirements

Disabling auto-run of software

The organisation must make sure that all of its computers, networking equipment and other related devices have auto-run of software is disabled.

Auto-run can cause serious cyber attacks, like ransomware, to get into the organisation's systems through downloaded software or compromised peripherals (e.g usb-stick).

Description

Strict guidelines on peripheral use: The organization has issued strict guidelines on the use of peripheral devices. These rules require a thorough security check of these devices before their usage in the organization's systems.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber Essentials - SEC-04: Disabling auto-run of software...
+2 requirements

Dissemination of security updates

In order to maintain the security of its products, the organization shall, in a timely manner, make available to its customers any security updates that address identified security issues. The distribution shall be made according to the terms of the product and service. The customer shall be notified of the importance of applying the security update, and also of the possible consequences of not applying it.

Description

According to the most recent version of the **2024 D&M Security Measures and Protocols** document, **Data & More (D&M)** maintains the security of the **D&M Compliance Server (DMCS)** through a structured, proactive, and transparent update lifecycle. This includes both the **timely application of security updates** and **clear customer communication via release notes** that emphasize their importance and associated risks.

Timely Maintenance and Security Updates

D&M ensures that all DMCS installations—whether SaaS, on-premise, or hybrid—receive security updates as part of a controlled and monitored lifecycle. This process includes:

- **Regular patching** of application containers and third-party services (e.g., Elasticsearch, NGINX, Kibana), all delivered via Docker.
- **Automated deployment** using Ansible scripts for consistent update rollouts, which reduces the risk of misconfiguration.
- **Client-specific support** to apply updates manually if automated mechanisms are not feasible due to local security policies.

All update operations require **outgoing internet access** on port 443, ensuring secure communication with D&M's deployment and monitoring infrastructure.

Customer Notification via Release Notes

D&M leverages **release notes** as the primary communication channel for informing customers about updates, especially those that resolve security issues. These release notes typically include:

- A **summary of the update**, specifying if it contains **security-relevant patches** or hardening improvements.
- An **indication of the update's urgency**, particularly when high-severity vulnerabilities are addressed.
- A **clear warning about the potential consequences** of not applying the update—for example, exposure to known attack vectors, degraded performance, or audit compliance risks.

Customers are advised to read the release notes prior to updating, as they provide context on the technical and operational impact of changes.

Risks of Not Applying Security Updates

Release communications explicitly highlight the **risks of delayed updates**, including:

- Potential for **unauthorized access** or **data exfiltration** due to unpatched vulnerabilities.
- Exposure to known threats mitigated in newer releases.
- Increased **operational overhead** if future patches require remediation of compounding issues.

Summary

Data & More maintains the security of the DMCS product through:

- A robust, **automated patching process** across all deployment models.
- **Timely availability** of security updates, with both proactive and customer-triggered options.
- Clear communication via **release notes**, detailing:
 - What the update fixes
 - Why it matters
 - What risks are incurred by not updating

This ensures that customers are both **protected and informed**, enabling them to make timely and secure operational decisions.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Vuln.8: Obligation to provide security updates

Enabling features of anti-exploitation

The protection of programs within the data processing environment is ensured by integrating and configuring features such as Microsoft Data Execution Prevention (DEP), Windows Defender Exploit Guard (WDEG), Apple System Integrity Protection (SIP), and Gatekeeper.

In parallel, system hardening is performed by adjusting settings and limiting systems to essential functionalities, thereby reducing potential vulnerabilities and aligning with anti-exploitation practices like those provided by DEP and WDEG.

Description

All employees have IT environment that is configured with features such as Microsoft Data Execution Prevention (DEP), Windows Defender Exploit Guard (WDEG), Apple System Integrity Protection (SIP), and Gatekeeper.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

CIS 18 - 10.5: Enable Anti-Exploitation Features

Establish a allowlist for approved scripts

The organization implements a comprehensive strategy to block unauthorized scripts from executing by employing multiple security measures. These include the use of digital signatures to verify the authenticity of scripts, ensuring only signed by a trusted certificate authority are allowed to run.

Description

A comprehensive strategy is implemented to block unauthorized scripts from executing within the organization's IT environment. Digital signatures are utilized to verify the authenticity of scripts, ensuring that only those signed by a trusted certificate authority are permitted to run. This process is continuously refined to align with the organization's operations, ensuring robust protection against malicious code.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

CIS 18 - 2.7: Allowlist Authorized Scripts

Instructing and training staff regarding malware

The organization regularly trains staff on the use of utilized malware protection, reporting malware attacks, and recovering from malware attacks.

Description

Malware protection software utilization: The organization trains staff comprehensively on how to optimally use installed malware protection software across all systems.

Proactive malware threat education: Regular informative sessions have been held by the organization to educate staff about the latest malware threats and how to identify potential risks.

Establishment of malware reporting processes: Clear and standard protocols have been developed and propagated by the organization to facilitate quick and accurate reporting of suspected or experienced malware attacks.

Recovery from malware attack training: The organization effectively trains staff on the required measures and actions to take post a malware attack for swift and safe recovery of systems.

Conduct of malware attack simulation exercises: The organization carries out simulated exercises of real-life malware attacks to enable staff to better understand the risks and reactions required during an actual event.

Assurance:

 Medium

Priority:

Low 

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

NIS2 - 21.2.b (logs): Logging and detection...

+4 requirements

Listing essential cybersecurity requirements, related to the product and cyber security processes

The manufacturer shall list the essential cyber security requirements (Annex I Part I and Part II) which are relevant to the product and the cyber security processes. This shall be done on a regular basis when needed and when developing the product.

Assurance:

 Weak

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Article 13.12: Technical documentation

Procedures and data sources for gathering reliable information about malware

The organization has defined policies that regularly collect up-to-date and reliable information about malware. Such can be e.g. mailing lists, magazines, blogs from security software vendors, or security news sites.

The purpose of the data sources is to verify the information on malware, to distinguish the scams from real malware and to ensure that the warnings received are truthful and informative.

Description

Subscription to mailing lists: The organization has subscribed to mailing lists from reputable cyber security firms and organizations, serving as a reliable source of information about emerging malware threats.

Access to security software vendor's resources: The organization frequently consults magazines, blogs, and other resources from trusted security software vendors to gain accurate and updated insights about malware.

Security news site monitoring: The organization has implemented a system of regularly monitoring credible security news sites for the latest information about malware threats.

Information verification process: The organization has introduced a process to verify the credibility of information on malware collected from various sources to distinguish real threats from hoaxes or scams.

Truthful Warning verification: The organization has incorporated a system to scrutinize the truthfulness and informativeness of warnings received from various sources, thereby ensuring only verified threats are acted upon.

Use of Threat Intelligence Platforms: The organization has enlisted the help of modern Threat Intelligence Platforms (TIPs) that aggregate data from multiple sources, providing reliable, consolidated, and actionable insights about existing and emerging malware threats.

Assurance:

 **Strong**

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked section:

Malware protection policy  Report

Linked requirements:

ISO 27001/27002:2022 - 8.7: Protection against malware...

+3 requirements

Process for deleting data from products

The organization should have a process for deleting user data from products that no longer needs to be stored. The process must ensure that the data is truly and irreversibly deleted. A simple deletion from the file system is not sufficient. The data must be overwritten or shredded. Means should be provided for users to delete their data on their own will.

Description

D&M have a process for deleting user data from products that no longer needs to be stored. The process ensure that the data is truly and irreversibly deleted.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Article 13.1(.2.m): Removing data

Product security testing

The organization shall test and review the security of the product(s) before and during development. The tests shall be performed at least at the following stages: concept evaluation, design, development, testing, release, and support.

Description

D&M test and review the security of the product(s) before and during development.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Vuln.3: Effective and regular testing

Publicly disclosing information about fixed vulnerabilities

The organization shall publicly promptly disclose information about fixed vulnerabilities, including a description of the vulnerabilities, information allowing users to identify the product with digital elements affected, the impacts of the vulnerabilities, their severity and clear and accessible information helping users to remediate the vulnerabilities. If there are any justified exceptions, a log must be kept of these.

Description

According to multiple release documents, **Data & More (D&M)** discloses security fixes and resolved vulnerabilities through its **public release notes**, which are distributed with each product version update. These release notes provide transparency to clients and internal stakeholders regarding **security improvements and bug resolutions**.



How Vulnerabilities Are Disclosed in D&M Release Notes

1. Dedicated "Security Update" Sections

Release notes typically include a section explicitly titled **"General Security Update"** or **"Bug Fixes"**, where resolved vulnerabilities or mitigated security issues are listed. For example, in the release for version **22.3.9**, the notes include:

- Removal of a **hardcoded password** (non-critical)
- Implementation of **PGP tokens for gRPC encryption**
- Other general **security hardening improvements**

These entries indicate proactive handling of potentially sensitive coding issues, while deliberately omitting specific CVE numbers or exploit vectors—likely to reduce risk until patches are widely applied.

2. Inclusion of Functional and Integration-Specific Security Fixes

Security-related updates are often embedded within functional fixes. For instance, in the recent **24.0.x** release:

- Runtime issues and **null pointer exceptions** were resolved

- **API behaviors** that could cause misconfiguration were corrected
- Authentication flows (e.g., Gmail integration and dashboard permissions) were refined to prevent data leakage or unauthorized access

While these aren't always labeled strictly as "security vulnerabilities," their **risk mitigation impact is documented**.

3. Security Update Transparency without Overexposure

D&M takes a **responsible disclosure approach**, which includes:

- Clearly stating when a release includes **security-related improvements**
- Avoiding direct disclosure of exploit paths or internal service names
- Disclosing enough technical detail for IT teams to assess urgency without increasing external attack surface

This approach ensures a **balanced transparency strategy**: customers can confidently track the application of security patches while limiting detailed disclosures that might benefit bad actors.

Summary

D&M ensures that information about fixed vulnerabilities is:

- Included in public **release notes** under clearly labeled categories (e.g., *"General Security Update"*, *"Bug Fixes"*)
- Written to **highlight the nature and impact** of each fix without exposing sensitive details
- Aligned with a **security-by-design ethos**, where even non-critical vulnerabilities (e.g., hardcoded credentials, integration flaws) are documented and addressed

If needed, D&M can provide customers with deeper context through controlled communications, but the **release notes themselves act as the first line of disclosure and compliance reporting**.

Assurance:



Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Vuln.4: Disclosing information about fixed vulnerabilities

Regular malware inspection of data systems supporting critical business processes

The data systems (and their content) that support critical business processes are regularly reviewed to locate malware. All unauthorized files and changes will be formally investigated.

Description

Regular malware inspection in critical data systems: The organization has instated thorough, routine inspections of all data systems supporting critical business processes to identify and locate potential malware.

Automated scanning systems: The organization has implemented automatic scanning systems that constantly monitor the data content of critical business process systems for malware.

Formal investigation of unauthorized changes: When unauthorized alterations or files are detected within data systems, the organization initiates a formal investigation to determine their origin and intent.

System data review: The organization implements a regular review of the data held within the systems that support critical business processes, ensuring no malware or unauthorized files have been introduced.

Incident response procedure: If potential malware is detected during routine inspections or automated scans, the organization has an incident response mechanism in place to address the issue promptly and comprehensively.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

NIS2 - 21.2.b (logs): Logging and detection...

+5 requirements

Selection and use of malware detection software on all devices

Centrally select and install malware detection and repair programs and update them regularly for preventive or regular scanning of computers and media.

Programs should check at least the following:

- files received over the network or storage media are scanned for malware before use
- email attachments and downloaded files are scanned for malware before use
- websites are scanned for malware

Description

Ongoing software updates The organization has ensured that the installed malware detection software is updated regularly. This procedure includes maintaining an up-to-date virus database for optimal threat detection and mitigation.

Scanning program for incoming files The organization's systems have been configured to scan files received over the network or through storage media for malware before usage.

Email and download scanning protocols The organization's malware detection software is set up to scan all email attachments and downloaded files for malware prior to their use.

Website scanning system The organization has mandated that all accessed websites are scanned for potential malware, adding an additional layer of protection against web - based threats.

Routine preventive scanning The organization has instituted a preventive scanning routine where computers and storage media are regularly scanned for potential malware infections.

Malware detection software selection and installation The organization has selected a premier, enterprise - level malware detection and repair program and installed it across all devices centrally.

Assurance:

 Strong

Priority:

Critical ⚡

Status:

Fully done

Owner:

κ k.

Linked requirements:

The Digital Operational Resilience Act (DORA) - Article 10: Detection...
+11 requirements

Unauthorized access to digital products is prevented

The organization must ensure that unauthorized access to offered digital products is prevented by suitable control mechanisms (e.g., authentication, identity and access management, encryption). The system should also report on attempts at unauthorized access.

Description

The organization must ensure that unauthorized access to offered digital products is prevented by suitable control mechanisms (e.g., authentication, identity and access management, encryption).

The system also report on attempts at unauthorized access.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Article 13.1(.2.d): Protection from unauthorised access

Whitelisting

Only software approved by the organization can be run on the devices. The organization should:

- Actively approve software before it is deployed
- Maintain a list of approved software
- Prevent users from installing unapproved software
- Create a list of separately allowed extensions
- Unauthorized extensions should be blocked

Description

Approval of software before deployment: The organization actively approves software before it is deployed on any devices. This involves a thorough security review of the software, ensuring it meets the organization's security standards and requirements.

Maintenance of an approved software list: The organization maintains a list of approved software. This list acts as a reference for staff as it only features software that has been vetted and approved by the organization and is allowed to run on its devices.

Prevention of non-approved software installation: The organization has implemented measures to prevent users from installing non-approved software. These measures include restriction of administrator rights, use of application whitelisting technology, and user education about the dangers of downloading third-party software.

Assurance:

 **Medium**

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber Essentials - MWP-05: Whitelisting...

+5 requirements

Employee guidelines

Employee guidelines related to malware protection describe the rules that need to be followed to limit the exposure to malware, report of incidents and to react to potential infections.

Technical guidelines

Instructions for protecting against malware

To protect our organization from malware, follow these instructions:

- Do not open attachments or links that are not from a verified source
- Do not open suspicious websites
- Do not connect peripherals to your computer if you do not know their origin
- Report suspicious events or equipment

Owner: Guideline acceptance:

DJ D. Junge 16/32 accepted 